INTEGRATED AIS · SECURE AI DEPLOYMENT

The Secure AI Deployment Buyer's Checklist

A 25-point self-assessment for moving AI from pilot to production — without giving up control of your data.

Integrated AIS — AI integration & security for regulated, security-conscious organisations. *"Don't wait to innovate, integrate."*

What you'll get

Most AI pilots never make it to production — and the ones that do often get there by quietly bypassing the controls that security, legal, and compliance would have insisted on. This checklist is the assessment we run before we'll agree to build anything: 25 concrete questions, grouped into seven themes, that surface where your AI exposure actually sits, which controls are missing, and what a board-defensible deployment needs to have in place before it goes live. Score yourself honestly, and by the end you'll know whether your next AI initiative is production-ready, needs a governance wrapper first, or is carrying risk nobody has signed off on. It's vendor-neutral, it names the hard trade-offs, and it's built to survive a red-team and a board — because that's the standard we hold our own builds to.

How to use this checklist

Score each item **Yes / Partial / No / Don't know**. Any "Don't know" is itself a finding — it means an unowned risk. Tally your score at the end.

- **Yes** = 2 points
- **Partial** = 1 point
- **No / Don't know** = 0 points

There are 25 items, so the maximum is 50. Interpretation is at the bottom.

1. Data control & sovereignty

The question every regulator, auditor, and board eventually asks: where does the data actually go?

1. **Data residency is mapped end-to-end.** You can state, for every AI use case, which jurisdictions the input data, prompts, embeddings, and outputs pass through and rest in — including sub-processors behind any AI vendor.

2. **You can deploy where the data must stay.** For workloads that cannot leave your environment, you have (or have a credible path to) on-premises inference — not just a cloud SaaS contract with reassurances in it.

3. **Training and retention terms are pinned down in writing.** You know, contractually, whether your prompts or data are used to train vendor models, how long they're retained, and how deletion is proven — not assumed from a marketing page.

4. **No sensitive data reaches a tool that shouldn't see it.** Personal, regulated, or commercially sensitive data is prevented — technically, not by policy alone — from flowing into consumer AI tools or unapproved endpoints.

2. Shadow AI & exposure

What's already running that nobody approved?

1. **You have a current inventory of AI in use.** You can list the AI tools, copilots, and API integrations actually in use across the organisation — including the unofficial ones staff adopted on their own.

2. **Shadow AI has a detection mechanism, not just a ban.** You can see (via network, DLP, or SaaS discovery) when new AI tools appear, rather than relying on a policy people quietly ignore.

3 **Third-party and embedded AI is accounted for.** You know which of your existing vendors have switched on AI features that now process your data, and whether that triggered a review.

4 **There's a safe, sanctioned alternative.** Staff have an approved AI option good enough that they don't need to reach for the unapproved one — the usual root cause of shadow AI.

3. Governance & accountability

Who owns the risk, and can they prove the organisation is in control?

1 **There is a named owner for AI risk.** A specific role — not "IT" or "the AI committee" in the abstract — is accountable for AI governance and can be pointed to on an org chart.

2 **You have a board-ready AI policy.** A written policy exists that defines acceptable use, approval routes, and prohibited use — one you'd be comfortable putting in front of the board or a regulator today.

3 **AI use cases pass through an approval gate before go-live.** New AI deployments are risk-assessed and signed off through a defined process, not stood up ad hoc by whichever team moved fastest.

4 **You're tracking the regulatory horizon.** Someone owns mapping obligations like the EU AI Act, sector rules, and data-protection law to your specific use cases — before an auditor does it for you.

5. **You align to a recognised framework.** Your approach maps to an external standard (e.g. NIST AI RMF) so your controls are defensible against a recognised benchmark rather than invented in-house.

4. Security of the AI system itself

The model is now part of your attack surface. Is it defended like one?

1. **AI-specific threats are in your threat model.** Prompt injection, data exfiltration via model outputs, jailbreaks, and model/supply-chain poisoning are explicitly considered — not folded vaguely into "cyber."

2. **Access to models and data is least-privilege.** Who and what can call which model, with which data, is scoped and enforced — including machine-to-machine and agent identities, not just human logins.

3. **Retrieval and tool access are bounded.** For any RAG or agentic system, the model can only reach the data and tools it genuinely needs, and can't be talked into reaching further.

4. **Secrets, keys, and API access are managed.** AI service credentials are held in a secrets manager, rotated, and monitored — not pasted into notebooks, prompts, or config files.

5. **The AI supply chain is vetted.** Base models, libraries, and fine-tuning data have known provenance, and you'd know if a dependency in that chain were compromised.

5. Reliability & the "confident-but-wrong" problem

Confident-but-wrong AI is the real risk. What stops a plausible wrong answer from becoming a decision?

1. **High-stakes outputs are checked, not trusted.** For decisions that carry regulatory, financial, or safety weight, there's a review, cross-check, or human-in-the-loop step between AI output and action.

2. **You measure accuracy against a real baseline.** You have evaluation data and metrics for each production use case, so "it seems to work" is replaced by a number you can defend.

3. **Failure modes are defined and handled.** You know what the system does when it's uncertain, out of scope, or wrong — and it degrades safely rather than answering confidently anyway.

4. **Outputs are traceable.** For a given AI-influenced decision, you can reconstruct what the model was asked, what it returned, and what data informed it — enough to answer "why did it do that?" after the fact.

6. Operations & lifecycle (MLOps)

Pilots are a demo. Production is a system somebody has to run on a Tuesday at 3am.

1. **Production AI is monitored.** Live systems are watched for drift, degradation, cost, and abuse — not deployed and forgotten once the pilot impressed someone.

2 **There's an incident and rollback path.** You can disable, roll back, or contain an AI system quickly if it misbehaves, and it's clear who is called when that happens.

7. Ownership & exit

Can you run it — and leave — without being held hostage?

1 **You're building capability, not dependence.** The deployment is designed to be handed to and operated by your own team, with documented architecture and no single vendor you can't leave — optional ongoing support by choice, not by lock-in.

Score yourself

Score	Maturity tier	What it means
40–50	**Tier 4 — Assured**	You have most of the controls a regulated deployment needs. The work now is assurance — red-teaming and evidence — not foundations.
25–39	**Tier 3 — Managed**	You're deploying AI faster than you're governing it. Likely defensible in parts, exposed in others. A structured review closes the gap before it's found for you.
10–24	**Tier 2 — Developing**	AI is in use (or imminent) without the guardrails to sign it off to a board or regulator. Prioritise inventory, ownership, and policy before scaling further.
Under 10	**Tier 1 — Ad hoc**	The priority isn't more AI — it's a clear-eyed map of what's already running and who owns the risk, before anything reaches production.

Count your "Don't knows" separately. Every one is an unowned risk hiding behind an assumption — and it's usually the "Don't knows," not the "Nos," that surface at the worst possible moment.

Where this comes from

This checklist is the front end of the phased, board-to-build approach Integrated AIS uses with regulated and security-conscious organisations: audit and discovery, business case, policy and governance, secure build and integration, red-team assurance, training, and handover. It's vendor-neutral by design — we don't resell anyone's models, so the assessment isn't steering you toward a product.

The principals — Theo Laredo and William Mann — are contactable directly.

Ready to turn your score into a plan?

If your self-assessment surfaced gaps you can't close on your own, the next step is small and low-risk: the **AI Exposure & Readiness Review** — a fixed price of £5,000, delivered in 2–3 weeks — that maps your shadow-AI exposure, governance gaps, and two or three highest-ROI use cases, ending in a board-ready summary. It's a standalone engagement, not credited against any later build.

→ Start the conversation

No pitch, no obligation — a working session with people who have to survive a board and a red-team, same as you.

© Integrated AIS · integratedais.com · Principals Theo Laredo & William Mann, contactable directly. Vendor-neutral by design.